

História de Usuário 01: Autenticação e Controle de Acesso

Descrição Geral

Como colaborador da LogiTrack, **Eu quero** realizar a autenticação no sistema fornecendo meu login e senha exclusivos, **Para que** eu possa acessar as funcionalidades de gestão de frota e dashboards de acordo com minhas permissões de acesso.

Detalhamento Técnico: Backend (Spring Boot)

A implementação utilizará Spring Boot com Java 17 ou superior e o ecossistema Spring Security.

- **Algoritmo de Criptografia:** As senhas serão obrigatoriamente processadas com o algoritmo **BCrypt** antes do armazenamento no banco de dados, impossibilitando a leitura de senhas em texto plano.
- **Gerenciamento de Sessão (JWT):** O sistema utilizará **JSON Web Tokens (JWT)** para autenticação *Stateless*.
- **Tempo de Expiração Estrito:** O token JWT terá uma validade inicial de **5 minutos**.
- **Expiração Deslizante (Sliding Expiration):** O backend será configurado para renovar o tempo de expiração em cada requisição válida efetuada pelo usuário. Se uma requisição autenticada for recebida dentro do período de validade, o backend emitirá um novo token (ou atualizará o tempo de vida) para garantir mais 5 minutos de acesso a partir daquele instante.
- **Controle de Roles (RBAC):** O sistema distinguirá entre perfis 'ADMIN' (Gestor) e 'OPERADOR', aplicando restrições de acesso diretamente nos métodos de serviço (Service Layer) através de anotações de segurança.

Detalhamento Técnico: Frontend (Vue.js + Bootstrap + Pinia)

A interface será construída como uma SPA (Single Page Application).

- **Framework de Estilização:** Será utilizado exclusivamente o **Bootstrap 5** para garantir uma interface funcional, responsiva e alinhada aos padrões de sistemas administrativos.
- **Gestão de Estado:** O **Pinia** será a ferramenta oficial para gerenciamento de estado global. Ele armazenará o token JWT, o nome do usuário e sua matrícula após o login.
- **Captura de Token e Renovação:** O frontend utilizará interceptadores do Axios para:
 1. Anexar o token atual no cabeçalho de todas as requisições.
 2. Monitorar o cabeçalho de resposta do backend; caso um novo token de "sliding expiration" seja enviado, a Store do Pinia deverá ser atualizada imediatamente com o novo valor e o novo tempo de expiração.

- **Guarda de Rotas:** O Vue Router impedirá o acesso a qualquer rota interna (como Dashboard ou Manutenções) se não houver um token válido e ativo na Store do Pinia. Caso o tempo de 5 minutos expire sem nova interação, o usuário será redirecionado automaticamente para a tela de login.

Regras de Negócio e Critérios de Aceite

Estas regras são os pilares de conformidade e segurança do sistema:

- **Regra de Unicidade:** O campo **matricula** é um identificador funcional obrigatório e deve ser único no sistema, sendo vedada a criação de dois usuários com a mesma matrícula.
- **Regra de Inatividade:** Se o usuário permanecer 5 minutos sem realizar nenhuma requisição ao backend (cliques que gerem chamadas de API), a sessão será considerada expirada e o acesso bloqueado.
- **Regra de Visibilidade de Dados:** Apenas o perfil 'ADMIN' terá permissão para visualizar a métrica de "Projeção Financeira" no Dashboard.
- **Regra de Exclusão:** A exclusão de registros de manutenção é uma funcionalidade restrita ao perfil 'ADMIN'. O perfil 'OPERADOR' terá acesso apenas à criação e atualização de status.
- **Validação de Credenciais:** O sistema deve retornar uma mensagem de erro genérica ("Usuário ou senha inválidos") para qualquer falha de autenticação, evitando a exposição de qual dado (login ou senha) está incorreto.

Definição da Estrutura de Dados (Texto)

A tabela de usuários será integrada ao banco de dados PostgreSQL conforme o esquema abaixo:

Tabela: usuarios

- **id:** Identificador numérico sequencial (SERIAL PRIMARY KEY).
- **nome:** Nome completo do colaborador (VARCHAR, NOT NULL).
- **matricula:** Código funcional único do colaborador (VARCHAR, UNIQUE, NOT NULL).
- **login:** Nome de usuário para acesso ao sistema (VARCHAR, UNIQUE, NOT NULL).
- **senha:** Hash da senha gerado via BCrypt (VARCHAR, NOT NULL).
- **perfil:** Define o nível de acesso, podendo ser 'ADMIN' ou 'OPERADOR' (VARCHAR, NOT NULL).